

Attestation of Compliance (AOC)

Document ID	Version	Owner	Effective Date	Framework	Classification
[AOC-PCI-001]	1.0	[Chief Information Security Officer / PCI Compliance Owner]	[YYYY-MM-DD]	PCI DSS v4.0.1	Confidential

Purpose

This Attestation of Compliance confirms that [Organisation Name] has completed an assessment of its cardholder data environment and payment security practices against PCI DSS v4.0.1.

This document is intended for submission to the relevant acquiring bank, payment brand, payment processor, customer, or other authorised relying party as formal confirmation of the organisation's compliance status for the assessed environment.

The purpose of this attestation is to:

- Confirm the scope and outcome of the PCI DSS assessment.
- Identify the assessed merchant or service provider environment.
- State whether the organisation has met the applicable PCI DSS requirements for the assessment period.
- Identify the person with authority to attest on behalf of the organisation.
- Reference the evidence and assessment records supporting the attestation.
- Establish retention and re-attestation expectations.

This attestation does not replace the underlying assessment workpapers, testing records, vulnerability scan results, penetration test reports, network diagrams, policies, procedures, or other evidence used to determine compliance.

Scope

This attestation applies to the cardholder data environment operated, managed, or otherwise controlled by [Organisation Name] for the processing, storage, or transmission of payment card account data.

Scope Element	Description
Legal entity assessed	[Organisation Legal Name]
Trading name, if different	[Trading Name]
Primary business address	[Address]
Assessment type	[Merchant / Service Provider / Both]
Merchant level or service provider category	[Applicable Level / Category]
Acquirer or payment brand recipient	[Acquirer / Payment Brand / Processor Name]
Assessment period covered	[Start Date] to [End Date]
Assessment completion date	[YYYY-MM-DD]
Assessment method	[Self-Assessment / Qualified Security Assessor-Led Assessment / Internal Security Assessor-Led Assessment]
Assessor organisation, if applicable	[QSA Company Name / Not Applicable]
Lead assessor, if applicable	[Assessor Name / Not Applicable]
Internal PCI compliance owner	[Name and Role]

The assessed environment includes the people, processes, technologies, facilities, systems, applications, databases, network segments, cloud services, third-party services, and operational practices that can affect the

security of account data.

The following payment channels, locations, systems, and services are included in this attestation:

In-Scope Area	Description	Included Components
Payment channels	[E-commerce / Mail order and telephone order / Card-present / Mobile / Other]	[Payment pages, terminals, payment applications, call centre systems, APIs, payment gateways]
Cardholder data environment	Systems and networks that store, process, or transmit account data	[System names, network zones, databases, application servers, security tools]
Connected systems	Systems that can affect the security of the cardholder data environment	[Identity platforms, logging platforms, management networks, administrative workstations, backup services]
Security services	Protective and monitoring services supporting the environment	[Firewall management, endpoint protection, vulnerability management, SIEM, file integrity monitoring, time synchronisation]
Cloud or hosted services	Externally hosted environments used for payment processing or security operations	[Cloud provider, hosted payment provider, managed service provider]
Physical locations	Sites where account data is handled or systems are administered	[Head office, data centre, call centre, branch locations]
Third-party service providers	Providers that store, process, transmit, or can affect the security of account data	[Payment gateway, processor, hosting provider, managed security provider, software provider]

The following areas are excluded from the assessment scope based on documented segmentation, outsourcing, or non-involvement in the storage, processing, transmission, or security of account data:

Out-of-Scope Area	Basis for Exclusion	Validation Performed
[Business unit / network / system]	[No connectivity to in-scope environment / no account data / fully outsourced]	[Network segmentation testing / data discovery / contract review / architecture review]
[Business unit / network / system]	[Reason]	[Validation method]

Where third-party service providers are relied upon, [Organisation Name] has confirmed that responsibility for payment security is defined, documented, and monitored. Third-party attestations, responsibility matrices, service agreements, and due diligence records have been reviewed where applicable.

This attestation covers only the environment described above. Any material change to payment processing, network architecture, cardholder data flows, hosting arrangements, service providers, payment applications, security controls, or business operations may require reassessment before this attestation can continue to be relied upon.

Attestation Statement

On behalf of [Organisation Name], I attest that the organisation has assessed the in-scope cardholder data environment against PCI DSS v4.0.1 and has determined the following compliance status as of [Assessment Completion Date]:

Attestation Item	Response
Compliance status	[Compliant / Not Compliant / Compliant with Remediation Completed / Compliant with Compensating Controls]
All applicable requirements assessed	[Yes / No]
All applicable requirements met	[Yes / No]
Account data storage reviewed	[Yes / No]
Sensitive authentication data storage after authorisation prohibited and validated	[Yes / No / Not Applicable]
Network segmentation relied upon	[Yes / No]
Network segmentation effectiveness validated	[Yes / No / Not Applicable]
Approved vulnerability scans completed where required	[Yes / No / Not Applicable]
Penetration testing completed where required	[Yes / No / Not Applicable]
Third-party service provider responsibilities reviewed	[Yes / No / Not Applicable]
Compensating controls used	[Yes / No]

Attestation Item	Response
Targeted risk analyses used to support defined control frequencies or approaches	[Yes / No]
Customized control approaches used	[Yes / No]
Remediation required after assessment	[Yes / No]
Remediation completed before attestation	[Yes / No / Not Applicable]

Based on the assessment performed and the evidence reviewed, [Organisation Name] attests that:

- The scope of the assessment was defined and validated using current data-flow diagrams, network diagrams, payment channel inventories, system inventories, service provider listings, and business process reviews.
- The organisation has identified where account data is stored, processed, transmitted, received, or could otherwise be exposed.
- Applicable security controls have been assessed using interviews, observation, system configuration review, sampling, technical testing, documentation review, and evidence inspection.
- The organisation has implemented controls intended to protect account data from unauthorised access, disclosure, modification, and misuse.
- Default security settings have been changed or removed where applicable.
- Network security controls are implemented to restrict access to the cardholder data environment to authorised traffic only.
- Stored account data is limited to what is necessary for business, legal, or regulatory purposes and is protected appropriately.
- Transmission of account data over public or untrusted networks is protected using strong cryptography.
- Malware protection, secure configuration, vulnerability management, patching, access control, authentication, logging, monitoring, security testing, and incident response practices are in operation for the assessed environment.
- Access to systems and account data is limited to authorised personnel and is managed through defined approval, authentication, review, and removal processes.
- Security events are logged, monitored, and investigated in accordance with the organisation's security operations procedures.
- Personnel with responsibilities affecting payment security are assigned clear duties and receive appropriate awareness or role-based training.
- Policies and procedures supporting payment security are documented, approved, communicated, and maintained.
- Third-party service providers that may affect payment security are identified, subject to due diligence, and monitored in accordance with the organisation's vendor governance process.
- Any findings identified during the assessment have been remediated or are documented in an approved remediation plan where a compliant attestation is not being made.

Where this attestation states that the organisation is compliant, it means that all applicable PCI DSS v4.0.1 requirements for the assessed environment were found to be in place as of the assessment completion date.

Where this attestation states that compensating controls are used, [Organisation Name] confirms that each compensating control has been documented, justified, assessed, and approved as providing protection consistent with the intent of the original requirement.

Where this attestation states that customized control approaches are used, [Organisation Name] confirms that the customized controls have been formally documented, supported by risk analysis, tested for effectiveness, and approved by accountable management.

Where this attestation states that remediation was required, the organisation confirms that corrective actions were tracked to closure before a compliant attestation was issued, unless this document is explicitly submitted as a non-compliant attestation with a remediation plan.

The following compliance outcome is attested:

Compliance Outcome	Selection
☐ Compliant	All applicable PCI DSS v4.0.1 requirements for the assessed environment were met as of the assessment completion date.
☐ Compliant after remediation	One or more gaps were identified during assessment and remediated before this attestation was signed.
☐ Compliant with approved compensating controls	Applicable requirements were met using documented and assessed compensating controls.
☐ Non-compliant	One or more applicable requirements were not met as of the assessment completion date. A remediation plan is required.
☐ Not applicable for certain requirements	Certain requirements did not apply based on documented scope, technologies, payment channels, or outsourced services.

If the compliance outcome is non-compliant, the following summary applies:

Open Issue	Business Impact	Remediation Owner	Target Completion Date	Current Status
[Issue summary]	[Impact]	[Owner]	[YYYY-MM-DD]	[Open / In Progress / Awaiting Validation]

By signing this attestation, the signatory confirms that the information provided is accurate to the best of their knowledge, that the assessment was performed in good faith, and that material facts affecting the compliance status of the assessed environment have not been knowingly omitted.

Signatory & Authority

The individual signing this attestation must have sufficient authority to make representations on behalf of [Organisation Name] regarding PCI DSS compliance, payment security governance, and the accuracy of the assessment outcome.

Acceptable signatories include the Chief Executive Officer, Chief Financial Officer, Chief Information Security Officer, Chief Information Officer, Head of Compliance, or another duly authorised executive or officer with accountability for payment security.

Role	Name	Authority Basis	Signature	Date
Authorised Executive Signatory	[Name]	[Executive role / Board delegation / Corporate authority]	[Signature]	[YYYY-MM-DD]
PCI Compliance Owner	[Name]	Responsible for PCI DSS compliance programme oversight	[Signature]	[YYYY-MM-DD]
Assessor, if applicable	[Name]	[Qualified Security Assessor / Internal Security Assessor / Not Applicable]	[Signature]	[YYYY-MM-DD]
Assessor organisation, if applicable	[Company Name]	Independent or authorised assessment provider	[Signature / Stamp if applicable]	[YYYY-MM-DD]

The authorised signatory confirms that they:

- Have reviewed this attestation before signature.
- Have appropriate authority to submit this attestation to the requesting acquirer, payment brand, processor, customer, or other authorised party.

- Understand that payment brands, acquirers, processors, and contractual counterparties may rely on this attestation.
- Understand that false, incomplete, or misleading statements may result in contractual, operational, financial, or compliance consequences.
- Will ensure that material changes affecting the assessed environment are evaluated for PCI DSS impact.
- Will ensure that compliance activities continue after the assessment date and are not treated solely as a point-in-time exercise.

If this attestation is signed electronically, the electronic signature must be applied using an approved corporate signing method that preserves signer identity, date, document integrity, and audit trail.

Evidence Referenced

This attestation is supported by assessment evidence retained by [Organisation Name] and, where applicable, by the assessor organisation. Evidence must be sufficient to demonstrate the assessment scope, testing performed, conclusions reached, remediation completed, and management approval.

The following evidence sources were referenced during preparation of this attestation:

Evidence Category	Evidence Reviewed	Owner / Custodian	Evidence Date or Period
PCI DSS assessment record	[Report on Compliance / Self-Assessment Questionnaire / Assessment workbook]	[PCI Compliance Owner / Assessor]	[YYYY-MM-DD]
Scope documentation	Cardholder data flows, payment channel inventory, system inventory, network diagrams, segmentation diagrams	[Architecture / Security Team]	[Date / Period]
Data discovery records	Results confirming locations of stored account data and absence of unauthorised storage	[Security Operations / Data Governance]	[Date / Period]
Policies and standards	Information security policy, access control standard, cryptography standard, logging standard, vulnerability management standard, incident response plan	[Policy Owner]	[Date / Period]
Network security evidence	Firewall rules, router configurations, change records, segmentation test results	[Network Security Team]	[Date / Period]
System hardening evidence	Secure configuration baselines, build records, configuration compliance results	[Infrastructure / Platform Team]	[Date / Period]
Vulnerability management evidence	Internal and external vulnerability scans, remediation tickets, risk acceptance records where applicable	[Vulnerability Management Team]	[Date / Period]
Approved external scan evidence	Passing external scan results from an approved scanning provider, where applicable	[PCI Compliance Owner]	[Date / Period]
Penetration testing evidence	Penetration test report, methodology, scope, findings, retest results	[Security Testing Team / Third Party]	[Date / Period]
Application security evidence	Secure development records, code review results, application testing results, change approvals	[Application Owner / Engineering]	[Date / Period]
Access control evidence	User access listings, privileged access reviews, authentication configuration, joiner-mover-leaver records	[Identity and Access Management]	[Date / Period]
Logging and monitoring evidence	Log source inventory, alerting configuration, event review records, incident tickets	[Security Operations Centre]	[Date / Period]
Malware protection evidence	Endpoint protection deployment, alert review, exception records	[Endpoint Security Team]	[Date / Period]

Evidence Category	Evidence Reviewed	Owner / Custodian	Evidence Date or Period
Physical security evidence	Access records, visitor logs, facility controls, media handling records where applicable	[Facilities / Operations]	[Date / Period]
Third-party service provider evidence	Service provider list, responsibility matrix, contracts, attestations, due diligence reviews	[Vendor Management / Procurement]	[Date / Period]
Training evidence	Security awareness completion records and role-based training records	[Human Resources / Security Awareness Owner]	[Date / Period]
Incident response evidence	Incident response plan, test records, contact lists, lessons learned	[Incident Response Owner]	[Date / Period]
Remediation evidence	Corrective action plans, tickets, closure evidence, retest results	[Control Owners]	[Date / Period]
Management approval	Compliance review minutes, risk committee approval, executive sign-off	[Governance Owner]	[Date / Period]

Evidence used for this attestation must be:

- Authentic, complete, and attributable to the relevant system, process, or owner.
- Current for the assessment period and aligned to the assessed environment.
- Protected from unauthorised alteration or deletion.
- Available for review by authorised assessors, acquirers, payment brands, processors, or other approved relying parties where required.
- Handled according to confidentiality and data protection requirements.

Sensitive evidence, including network diagrams, vulnerability reports, penetration test results, authentication settings, encryption details, and security monitoring records, must not be distributed with this attestation unless explicitly required and approved by the information security owner.

Where evidence contains account data, secrets, credentials, security configurations, or commercially sensitive information, it must be redacted or shared through approved secure channels only.

Frequency

This attestation must be completed at least annually or more frequently where required by the acquiring bank, payment brand, processor, customer contract, or applicable compliance programme.

A new or updated attestation must also be considered when any of the following occur:

Trigger Event	Required Action	Owner
Material change to payment processing	Review scope and determine whether reassessment is required	PCI Compliance Owner
New payment channel introduced	Update data flows, assess controls, and validate applicability	Business Owner / Security
Migration to new hosting, cloud, or network architecture	Revalidate scope, segmentation, and security control operation	Architecture / Security
New service provider affecting payment security	Complete due diligence, define responsibilities, and assess impact	Vendor Management
Change in acquirer, processor, or payment brand reporting obligation	Confirm required attestation format and submission deadline	Finance / Compliance
Security incident involving account data or in-scope systems	Conduct incident response, notify as required, and reassess control effectiveness	Incident Response Owner
Significant control failure or overdue remediation	Escalate to governance forum and determine whether attestation remains valid	PCI Compliance Owner
Merger, acquisition, divestiture, or business restructuring	Reassess scope, payment flows, ownership, and compliance obligations	Executive Sponsor

Trigger Event	Required Action	Owner
Expiry of previous attestation	Complete annual assessment and submit updated attestation	PCI Compliance Owner

The standard attestation timeline is as follows:

Activity	Target Timing	Responsible Party
Confirm reporting requirements with acquirer or payment brand	90 days before attestation due date	PCI Compliance Owner
Refresh payment inventory and scope documentation	75 days before attestation due date	Security Architecture / Business Owners
Collect and review control evidence	60 days before attestation due date	Control Owners
Complete technical testing and scans	45 days before attestation due date	Security Testing / Vulnerability Management
Remediate identified gaps	30 days before attestation due date	Assigned Remediation Owners
Validate remediation and final evidence	15 days before attestation due date	PCI Compliance Owner / Assessor
Obtain management review and signature	10 days before attestation due date	Authorised Signatory
Submit attestation to authorised recipient	On or before due date	PCI Compliance Owner
Archive final attestation and supporting records	Within 5 business days of submission	Compliance Records Owner

Compliance with PCI DSS is an ongoing obligation. The organisation must maintain security controls throughout the year and must not rely solely on annual assessment activity to detect or correct control failures.

Records & Retention

The final signed attestation and supporting records must be retained in accordance with [Organisation Name]'s records management, legal, contractual, and compliance obligations.

At a minimum, the following records must be retained:

Record Type	Minimum Retention Period	Repository	Access Restrictions
Signed Attestation of Compliance	[Minimum 3 years or organisation-defined period]	[GRC repository / Compliance records system]	PCI Compliance Owner, Legal, Internal Audit, authorised executives
Submitted copy and delivery confirmation	[Minimum 3 years or organisation-defined period]	[GRC repository / Secure document store]	PCI Compliance Owner, Finance, Legal
Assessment report or questionnaire	[Minimum 3 years or organisation-defined period]	[GRC repository]	PCI Compliance Owner, Assessor, Internal Audit
Scope documentation	[Minimum 3 years or organisation-defined period]	[Architecture repository / GRC repository]	Security, Architecture, Compliance
Evidence index and assessment workpapers	[Minimum 3 years or organisation-defined period]	[Secure evidence repository]	PCI Compliance Owner, Assessor, Internal Audit
Vulnerability scan and remediation records	[Minimum 3 years or organisation-defined period]	[Vulnerability management platform]	Security Operations, Compliance
Penetration test reports and retest records	[Minimum 3 years or organisation-defined period]	[Secure security testing repository]	Security Leadership, Compliance, authorised technical owners
Third-party attestations and responsibility matrices	[Minimum 3 years or organisation-defined period]	[Vendor management system / GRC repository]	Vendor Management, Compliance, Legal
Management approvals and sign-off records	[Minimum 3 years or organisation-defined period]	[GRC repository]	Compliance, Legal, authorised executives
Remediation plans and closure evidence	[Minimum 3 years or organisation-defined period]	[Ticketing system / GRC repository]	Control Owners, Compliance, Internal Audit

Records must be protected against unauthorised access, alteration, disclosure, and destruction. Access to records must be granted only to personnel with a legitimate business need.

The Compliance Records Owner must ensure that:

- The final signed version is clearly distinguishable from drafts.
- The submitted version matches the approved signed version.

- Evidence supporting the attestation is indexed and retrievable.
- Sensitive security evidence is stored in restricted repositories.
- Retention periods are applied consistently.
- Records subject to legal hold, investigation, dispute, or regulatory request are preserved until released by Legal.
- Disposal of expired records is authorised, logged, and performed securely.

This attestation is classified as Confidential. Distribution is limited to [Organisation Name], the relevant acquirer, payment brand, processor, assessor, authorised customers, legal counsel, internal audit, and other parties explicitly approved by the PCI Compliance Owner or Legal.

Unauthorised copying, forwarding, publication, or external disclosure of this attestation or its supporting evidence is prohibited.